

**MATA KULIAH KOM1315 — KEAMANAN INFORMASI
SEMESTER GENAP 2026**

**Architecture Diagram dan
Rancangan Keamanan Sistem**

**IPB Space
Integrated Campus Facility Booking Platform**

Kelompok : 11
Mata Kuliah : KOM1315 Keamanan Informasi
Semester : Genap 2026

Anggota :
Daffa Aulia Musyaffa Subyantoro (G6401231028)
Hakim Ilyas Azhar (G6401231077)
Kivi Adelio (G6401231047)

1. Ringkasan Rancangan

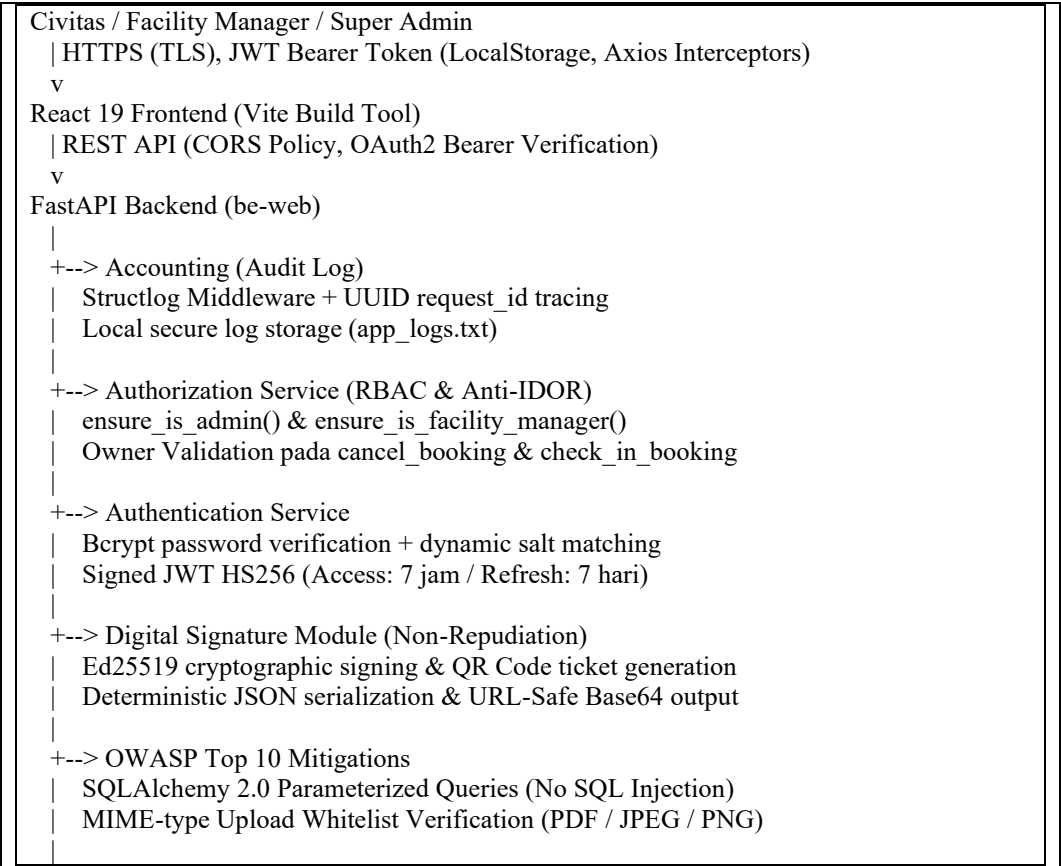
IPB Space merupakan platform pemesanan fasilitas kampus terpadu yang dirancang dengan mempertimbangkan prinsip security by design secara menyeluruh. Sistem ini dibangun di atas tumpukan teknologi modern yang terdiri atas frontend berbasis React 19 dengan Vite, backend FastAPI (Python), dan basis data relasional PostgreSQL yang diisolasi dalam jaringan privat Docker. Setiap lapisan arsitektur dirancang untuk saling memvalidasi kepercayaan (trust) dan menegakkan prinsip hak akses minimum (least privilege).

Rancangan keamanan sistem ini mencakup implementasi mekanisme Authentication, Authorization, dan Accounting (AAA) yang komprehensif. Autentikasi berbasis JWT dengan algoritma HS256 dikombinasikan dengan hashing kata sandi menggunakan Bcrypt bersalting dinamis. Otorisasi diterapkan melalui model Role-Based Access Control (RBAC) dengan tiga peran hierarkis. Accounting diimplementasikan melalui pencatatan audit berbasis Structlog dengan pelacakan UUID per permintaan.

Fitur unggulan sistem ini adalah implementasi digital signature berbasis kriptografi asimetris Kurva Eliptik Ed25519 untuk penerbitan tiket pemesanan yang dapat diverifikasi secara offline. Selain itu, sistem menerapkan mitigasi komprehensif terhadap sepuluh kategori kerentanan teratas OWASP, meliputi perlindungan terhadap injeksi SQL, keamanan unggahan berkas, dan pembatasan CORS yang ketat.

2. Diagram Arsitektur Keamanan

Diagram berikut menggambarkan alur data dan penegakan kontrol keamanan di setiap lapisan arsitektur sistem IPB Space, dari client browser hingga lapisan penyimpanan data.



SQLAlchemy 2.0 Async ORM / Alembic (Versioned Migrations)
▼
Docker Private Network Boundary (Isolated Network)
▼
PostgreSQL Database (Isolated Data Layer)

3. Komponen dan Trust Boundary

Tabel berikut merinci setiap komponen utama sistem beserta tanggung jawab fungsionalnya dan kontrol keamanan yang diterapkan.

Komponen	Tanggung Jawab	Kontrol Keamanan Utama
React 19 Frontend	Antarmuka pengguna, manajemen sesi klien, inisiasi permintaan API, rendering QR Code tiket.	Axios Interceptors untuk rotasi token otomatis; LocalStorage untuk persistensi sesi; validasi form sisi klien.
FastAPI Backend	Pemrosesan logika bisnis, penegakan autentikasi & otorisasi, penerbitan tiket, audit logging.	JWT HS256 verification; RBAC via Dependency Injection; CORS whitelist; MIME-type filtering; Ed25519 signing.
PostgreSQL	Penyimpanan persisten seluruh entitas: pengguna, pemesanan, fasilitas, dokumen izin.	Isolasi Docker Private Network; akses eksklusif via ORM; parameterized queries mencegah SQL Injection.
Structlog Middleware	Pencatatan audit seluruh aktivitas sistem dengan konteks request yang dapat ditelusuri.	UUID request_id per permintaan; log tersimpan di app_logs.txt; akses dibatasi Super Admin via /system/logs.
CryptographicSigner	Penerbitan dan verifikasi tanda tangan digital tiket pemesanan berbasis kunci asimetris.	Ed25519 (Curve25519); deterministic serialization; URL-Safe Base64 output; verifikasi via public key only.
Alembic Migration	Pengelolaan evolusi skema basis data secara terversi dan reproducible.	Migrasi bersifat idempoten dan dapat di-rollback; riwayat perubahan skema terdokumentasi.
Docker Network	Isolasi jaringan antar layanan (backend ↔ database).	PostgreSQL tidak terekspos ke jaringan publik; komunikasi internal melalui private bridge network.

4. Authentication Design

4.1. Password Hashing dengan Bcrypt

Penyimpanan kata sandi menggunakan algoritma Bcrypt dengan ketentuan berikut:

- **Dynamic Random Salt:** Setiap kata sandi menghasilkan salt acak yang unik pada saat proses hashing, sehingga serangan rainbow table menjadi tidak efektif.
- **Work Factor (Cost Factor):** Bcrypt menerapkan faktor kerja adaptif yang membuat proses hashing secara komputasi mahal, sehingga serangan brute-force dan dictionary attack menjadi tidak praktis.
- **One-Way Function:** Hash Bcrypt bersifat tidak reversibel. Verifikasi dilakukan dengan membandingkan hash dari kata sandi yang dimasukkan terhadap hash yang tersimpan.

4.2. Manajemen Sesi dengan JWT

Sistem menggunakan pasangan Access Token dan Refresh Token berbasis JSON Web Token (JWT) untuk manajemen sesi stateless:

- Algoritma: HS256 (HMAC-SHA256) dengan kunci rahasia yang disimpan eksklusif di berkas .env.
- Access Token: Memiliki masa berlaku 7 jam. Dikirimkan melalui header HTTP Authorization: Bearer <token>.
- Refresh Token: Memiliki masa berlaku 7 hari. Axios Interceptors pada frontend menangani proses refresh ini secara transparan.
- OAuth2 Bearer Token Protection: Endpoint yang memerlukan autentikasi divalidasi format dan integritasnya sebelum diteruskan ke logika bisnis.

5. Authorization Design

5.1. Role-Based Access Control (RBAC)

Sistem IPB Space menerapkan tiga peran resmi dengan hak akses hierarkis dan terpisah, divalidasi melalui Dependency Injection FastAPI.

Role	Hak Akses	Deskripsi & Batasan
civitas	Melihat fasilitas; membuat, melihat, membatalkan pemesanan milik sendiri; check-in tiket milik sendiri.	Peran dasar bagi seluruh anggota sivitas akademika IPB. Tidak dapat mengakses atau memodifikasi data pengguna lain.
facility_manager	Semua hak civitas; menyetujui/menolak pemesanan; mengelola data fasilitas yang ditugaskan.	Divalidasi via ensure_is_facility_manager. Tidak memiliki akses ke fungsi administratif sistem.
admin	Akses penuh: manajemen pengguna, melihat log sistem (/system/logs), semua hak role di bawahnya.	Divalidasi via ensure_is_admin. Super Admin satu-satunya yang dapat mengakses endpoint audit log.

5.2. Mitigasi Insecure Direct Object Reference (IDOR)

Potensi kerentanan IDOR dimitigasi secara eksplisit melalui Owner Validation pada dua operasi kritis:

- cancel_booking: Sistem memverifikasi bahwa user_id dari token JWT aktif identik dengan user_id pada rekaman pemesanan di basis data.
- check_in_booking: Divalidasi secara kriptografis melalui verifikasi tanda tangan Ed25519 dan juga dilindungi validasi kepemilikan.

6. Accounting dan Audit Logging

6.1. Mekanisme Structlog dan Request Tracing

- UUID request_id: UUID unik dihasilkan middleware di main.py untuk setiap permintaan HTTP yang masuk, memudahkan diagnosis insiden keamanan.
- Penyimpanan Log: Seluruh log disimpan secara lokal di berkas app_logs.txt dan tidak dapat diakses langsung oleh pengguna biasa.

- Akses Log: Endpoint /system/logs hanya dapat diakses oleh pengguna dengan peran admin, dijamin melalui dependency ensure_is_admin.

6.2. Kategori Event Audit

Kategori event utama yang dicatat dalam log audit:

Kode Event	Tingkat	Konteks yang Dicatat
LOGIN_SUCCESS	INFO	request_id, user_id, username, role, ip_address, timestamp
LOGIN_FAIL	WARNING	request_id, username (input), reason, ip_address, timestamp
BOOKING_CREATED	INFO	request_id, booking_id, user_id, facility_id, start time, end time, timestamp
BOOKING_APPROVED	INFO	request_id, booking_id, facility_manager_id, action (approved/rejected), timestamp
BOOKING_CANCELLED	INFO	request_id, booking_id, cancelled_by (user_id), reason, timestamp
CHECKIN_SUCCESS	INFO	request_id, booking_id, verified_by, signature_valid: true, timestamp
CHECKIN_FAIL	WARNING	request_id, token_fragment, reason (invalid signature / expired / already used), timestamp
FACILITY_MUTATED	INFO	request_id, facility_id, action (created/updated/deleted), performed_by, timestamp
UNAUTHORIZED_ACCESS	ERROR	request_id, user_id, attempted_endpoint, required_role, actual_role, timestamp

7. Klasifikasi dan Proteksi Data

Seluruh data diklasifikasikan berdasarkan tingkat sensitivitasnya dan dilindungi dengan kontrol yang sepadan.

Data / Kolom	Risiko Jika Bocor	Rencana Perlindungan
Password Hash (hashed_password)	Akun pengambilalihan jika hash retak via brute-force.	Hashing Bcrypt dengan dynamic random salt; cost factor tinggi; tidak pernah di-log atau dikembalikan dalam respons API.
Data Pribadi Civitas (nama, email, NIM/NIP)	Pelanggaran privasi, phishing bertarget, penyalahgunaan identitas.	Enkripsi transport TLS; akses terbatas sesuai RBAC; validasi kepemilikan pada seluruh endpoint data profil.
Berkas Dokumen Izin (PDF, JPEG, PNG)	Upload malware, path traversal, eksekusi kode berbahaya via file extension spoofing.	Validasi MIME-type ketat — hanya application/pdf, image/jpeg, image/png; nama berkas di-sanitize.
Secret Keys di .env (JWT_SECRET, SIGNING_PRIVATE_KEY)	Pemalsuan token JWT sembarangan; pemalsuan tanda tangan tiket.	Berkas .env masuk .gitignore wajib; tidak pernah di-hardcode dalam kode sumber.
Payload Tanda Tangan Ed25519 (data tiket)	Pemalsuan tiket jika kunci privat bocor.	Kunci privat hanya di .env; verifikasi check-in hanya memerlukan kunci publik.

8. Digital Signature Design

8.1. Dasar Matematis Ed25519

Sistem IPB Space mengimplementasikan tanda tangan digital menggunakan skema Ed25519 (Edwards-curve Digital Signature Algorithm) di atas kurva eliptik Curve25519:

- Kurva: Edwards25519 dalam representasi twisted Edwards.
- Ukuran Kunci: Kunci privat 256-bit, kunci publik 256-bit, tanda tangan 512-bit (64 byte).
- Deterministic: Tidak bergantung pada sumber keacakan saat penandatanganan — kritis untuk reproduktibilitas audit.
- Keamanan: Resistansi terhadap serangan timing attack (constant-time) dan small subgroup attack.

8.2. Alur Penerbitan Tiket

1. KONSTRUKSI PAYLOAD

```
booking_data = { "booking_id": "uuid-...", "user_id": 42, ... }
```

2. DETERMINISTIC SERIALIZATION

```
json_bytes = json.dumps(booking_data, sort_keys=True).encode("utf-8")
```

3. PENANDATANGANAN (Ed25519)

```
signature_bytes = SIGNING_PRIVATE_KEY.sign(json_bytes) # 64 byte output
```

4. ENCODING URL-SAFE BASE64

```
payload_b64 = base64.urlsafe_b64encode(json_bytes).rstrip(b'=').decode()
signature_b64 = base64.urlsafe_b64encode(signature_bytes).rstrip(b'=').decode()
token_string = f'{payload_b64}.{signature_b64}'
```

5. EMBEDDING DALAM QR CODE

QR Code dibuat dari token_string dan dicetak / ditampilkan pada tiket digital

8.3. Alur Verifikasi Check-In (Offline-Capable)

1. PETUGAS SCAN QR CODE

token_string dikirim ke endpoint: POST /verify/{token}

2. PARSING TOKEN

```
[payload_b64, signature_b64] = token_string.split(".")
```

3. DECODE BASE64

```
json_bytes = base64.urlsafe_b64decode(payload_b64 + "==")
signature_bytes = base64.urlsafe_b64decode(signature_b64 + "==")
```

4. VERIFIKASI KRIPTOGRAFIS (hanya butuh SIGNING_PUBLIC_KEY)

```
SIGNING_PUBLIC_KEY.verify(signature_bytes, json_bytes)
→ Jika VALID : integritas dan keaslian tiket terkonfirmasi
→ Jika INVALID: BadSignatureError → tolak check-in
```

5. PARSE DAN VALIDASI SEMANTIK (opsional, online)

```
booking_data = json.loads(json_bytes)
Periksa: status == "approved", waktu masih valid, belum digunakan
```

Tahap 4 (verifikasi kriptografis) tidak memerlukan koneksi database karena hanya menggunakan kunci publik yang sudah terdistribusi kepada petugas. Hal ini memungkinkan verifikasi tiket tetap berfungsi bahkan ketika koneksi jaringan ke server tidak tersedia (offline verification).

9. Manajemen Kunci dan Komunikasi Aman

9.1. Protokol Komunikasi

- HTTPS / TLS Wajib: Seluruh komunikasi antara browser klien dan server backend wajib menggunakan HTTPS. Transmisi kredensial, token JWT, dan payload tiket tidak pernah dilakukan melalui koneksi HTTP.
- HTTP Strict Transport Security (HSTS): Direkomendasikan dikonfigurasi pada lapisan reverse proxy (Nginx/Caddy) guna mencegah downgrade attack ke HTTP biasa.

9.2. Isolasi Basis Data

- Docker Private Network: Kontainer PostgreSQL dikonfigurasi hanya dalam jaringan privat internal Docker. Port 5432 tidak dipublikasikan ke jaringan eksternal.
- Akses Eksklusif via Backend: Satu-satunya titik akses yang sah adalah kontainer FastAPI dalam jaringan yang sama, seluruh kueri melalui ORM SQLAlchemy 2.0.

9.3. Manajemen Rahasia (Secret Management)

- Larangan Hardcoded Keys: Variabel rahasia (JWT_SECRET_KEY, DATABASE_URL, SIGNING_PRIVATE_KEY, SIGNING_PUBLIC_KEY) tidak pernah ditulis langsung dalam kode sumber.
- Wajib .gitignore: Berkas .env wajib terdaftar dalam .gitignore repositori. Berkas .env.example disediakan sebagai templat onboarding.
- Prinsip Distribusi Kunci Minimal: Kunci privat Ed25519 hanya boleh ada di server backend. Kunci publik dapat didistribusikan kepada sistem verifikasi tanpa membahayakan keamanan.
- Rotasi Kunci: Prosedur rotasi JWT Secret Key dan pasangan kunci Ed25519 harus didokumentasikan dan dijalankan secara berkala atau segera setelah indikasi kompromi.

10. Acceptance Checklist

Kriteria penerimaan yang harus dipenuhi seluruh komponen keamanan sistem sebelum deployment ke lingkungan produksi.

Domain	Kriteria Penerimaan	Status Target
Authentication	Password disimpan sebagai hash Bcrypt dengan dynamic salt; tidak ada plaintext password di log atau respons API.	✓ Wajib
Authentication	Access Token kedaluwarsa tepat 7 jam; Refresh Token tepat 7 hari; token invalid setelah logout.	✓ Wajib
Authentication	Axios Interceptors berhasil melakukan auto-refresh tanpa intervensi pengguna; sesi tidak terputus saat token expired.	✓ Wajib
Authorization	Endpoint terlindungi menolak akses dengan HTTP 403 jika role tidak sesuai; dependency injection ensure_is_admin berfungsi pada seluruh endpoint relevan.	✓ Wajib
Authorization	Pengguna civitas tidak dapat membatalkan atau melakukan check-in atas pemesanan milik pengguna lain (IDOR test case lulus).	✓ Wajib

Accounting	Setiap permintaan tercatat dengan UUID request_id yang unik; entri log memuat timestamp, user context, dan kode event.	✓ Wajib
Accounting	Endpoint /system/logs mengembalikan 403 untuk role civitas dan facility_manager; hanya admin yang mendapatkan respons 200.	✓ Wajib
Data Protection	Upload berkas dengan MIME-type selain application/pdf, image/jpeg, image/png ditolak dengan HTTP 400.	✓ Wajib
Data Protection	Berkas .env tidak terdapat dalam riwayat commit repositori git; .gitignore mencantumkan .env secara eksplisit.	✓ Wajib
Data Protection	Seluruh komunikasi antara client dan server menggunakan HTTPS; tidak ada endpoint aktif di atas HTTP tanpa redirect.	✓ Wajib
Data Protection	PostgreSQL tidak dapat dihubungi dari luar Docker private network; koneksi langsung ke port 5432 dari host eksternal ditolak.	✓ Wajib
Digital Signature	Tanda tangan Ed25519 yang valid diterima oleh endpoint /verify/{token}; tanda tangan yang dimodifikasi ditolak.	✓ Wajib
Digital Signature	Serialisasi payload menggunakan sort_keys=True; dua penerbitan tiket dengan data identik menghasilkan token yang identik (deterministic).	✓ Wajib
Digital Signature	Verifikasi tiket berhasil dilakukan menggunakan hanya kunci publik (SIGNING_PUBLIC_KEY) tanpa akses ke kunci privat atau basis data (offline test case lulus).	✓ Wajib
OWASP	SQL Injection test case (seperti ' OR '1'='1') tidak menghasilkan data atau error yang mengekspos struktur basis data.	✓ Wajib
OWASP	CORS: permintaan dari origin tidak terdaftar ditolak; hanya origin terpercaya yang dikonfigurasi di main.py mendapatkan respons.	✓ Wajib